Saudi GRC Platform

Evidence Library

Source: `evidence-library.md`

06 — Evidence Library

Per-domain catalogue of the evidence types the platform stores and presents to auditors / regulators.

Storage model: every entry below maps to a row in `evidence.evidence_items` with `evidence_type` set per the "Evidence name" column. Versions live in `evidence.evidence_versions` (SHA-256 chain). Links to the originating control / risk / incident are in `evidence.evidence_links`.

Evidence name	Description	Owner	Frequency	File types	Expiry rule	Review rule	Approval	Module	Regulatory source	Sig req.
BCM Charter	Top-level BCM programme charter	BCM Manager	Annual	PDF	12 months	Annual mgmt review	Board	BCM	ISO 22301 §5.1	✓
BIA Report	Per-service business impact analysis	BIA Owner	Annual + change-driven	PDF, XLSX	12 months	Annual	BCM Manager	BCM	ISO 22301 §8.2.2	✓
BCP Document	Service BCP playbook	BCM Manager	12 months	PDF	12 months	Annual + post-test	BCM Manager	BCM	ISO 22301 §8.4	✓
DRP Playbook	System DR runbook	DR Owner	12 months	PDF, MD	12 months	After every test	CIO + BCM	BCM	ISO 22301 §8.4 + NCA ECC	✓
DR Test After-Action	Outcome + lessons from each DR test	DR Owner	Per test (annual+)	PDF	24 months	n/a	BCM Manager	BCM	ISO 22301 §8.5	—
Crisis Declaration Log	Crisis activation timeline	Crisis Manager	Per event	PDF, JSON	60 months	Per event	Executive	BCM	NRC	✓
Crisis Comms Record	Distribution log of crisis communications	Comms Lead	Per event	PDF	60 months	n/a	Crisis Manager	BCM	NRC	—
BCM Exercise Report	After-action from BCM exercise	BCM Manager	Per exercise	PDF	24 months	n/a	BCM Manager	BCM	ISO 22301 §8.5	—
Supplier Due-Diligence Pack	Vendor onboarding due diligence	Procurement	Onboarding + biennial	PDF, XLSX	24 months	Biennial	Vendor Risk Mgr	SCM	SAMA outsourcing	—

Evidence name	Description	Owner	Frequency	File types	Expiry rule	Review rule	Approval	Module	Regulatory source	Sig req.
Alternate Supplier Vetting	Vetting of standby vendor	Vendor Risk Mgr	Annual	PDF	12 months	Annual	Vendor Risk Mgr	SCM	SAMA outsourcing	—
Exit-Plan Document	90-day vendor exit plan	Procurement	Per critical vendor	PDF	24 months	Annual	COO	SCM	SAMA outsourcing	✓
Exit-Plan Rehearsal After-Action	Outcome of exit rehearsal	Vendor Risk Mgr	Annual	PDF	24 months	n/a	COO	SCM	SAMA	—
Supplier Resilience Test After-Action	Tabletop / failover / SLA / joint-crisis report	Vendor Risk Mgr	Annual+	PDF	24 months	n/a	CIO + BCM	SCM	SAMA + ISO 22301	—
Fourth-Party Validation Memo	Validation of fourth-party relationship	Vendor Risk Mgr	Annual	PDF	12 months	Annual	Vendor Risk Mgr	SCM	SAMA + NCA	—
Contract Addendum (Flow-down)	Flow-down clauses to sub-processors	Legal	Per vendor	PDF	Contract term	Per contract change	GC	SCM	SAMA + PDPL Art. 28	✓
ERM Risk Register Snapshot	Periodic register dump	Risk Mgr	Quarterly	PDF, XLSX	36 months	Quarterly	Risk Committee	ERM	ISO 31000	—
Risk Acceptance Memo	Above-appetite acceptance	Risk Owner	Per acceptance	PDF	Until expiry	Annual	CRO	ERM	ISO 31000 + ISO 27001	✓
KRI Monthly Snapshot	KRI values+breaches	Risk Mgr	Monthly	XLSX, PDF	12 months	Monthly	Risk Committee	ERM	ISO 31000	—
Scenario Analysis Pack	Monte Carlo / stress / what-if calculation	Risk Analyst	Per scenario	PDF, XLSX	24 months	Per use	Risk Mgr	ERM	ISO 31000	✓ at APPROVED
Risk Committee Minutes	Per-meeting	Committee Secretary	Quarterly	PDF	60 months	Per meeting	Chair	ERM	ISO 31000	✓

Evidence name	Description	Owner	Frequency	File types	Expiry rule	Review rule	Approval	Module	Regulatory source	Sig req.
NCA Self-Assessment Pack	Annual ECC + CSCC + CCC + OTCC self-assessment	NCA Compliance Owner	Annual	PDF	12 months	Annual	CISO	NCA	NCA ECC + CSCC + CCC + OTCC	✓
NCA Filing PDF	Filed self-assessment	CISO Office	Annual	PDF	Permanent	n/a	CISO	NCA	NCA ECC §3	✓
NCA Control Attestation	Per-control owner attestation	Control Owner	Annual	PDF	12 months	Annual	Control Owner	NCA	NCA ECC	—
Pentest Report	Annual penetration test	CISO Office	Annual	PDF	12 months	n/a	CISO	Cyber	NCA + PCI DSS 11.4	—
Vulnerability Scan Output	Quarterly internal + ASV external	SOC	Quarterly	PDF, CSV	12 months	Quarterly	CISO	Cyber	PCI DSS + NCA	—
Asset Inventory Snapshot	Per-system inventory	Asset Owner	Quarterly	XLSX	12 months	Quarterly	CIO	Cyber	NCA ECC §2	—
Cyber Incident Report	Per-incident timeline + classification + lessons	Incident Manager	Per incident	PDF	60 months	n/a	CISO	Incident	NCA + SAMA	✓ at NOTIFIED
RCA Report	Root cause analysis (5-Whys/Fishbone/Pareto)	RCA Facilitator	Per incident	PDF	60 months	n/a	RCA Approver	Incident	ISO 27035	✓ at APPROVED
CISO Attestation (NCA filing)	Annual CISO sign-off	CISO	Annual	PDF	12 months	n/a	CISO	NCA	NCA ECC	✓
ROPA Snapshot	Per-tenant ROPA dump	DPO	Annual	PDF, XLSX	12 months	Annual	DPO	Privacy	PDPL Art. 31	—
Privacy Notice (Published)	The signed published notice	DPO	Per version	PDF	Until superseded	n/a	DPO	Privacy	PDPL Art. 12	✓ at PUBLISH

Evidence name	Description	Owner	Frequency	File types	Expiry rule	Review rule	Approval	Module	Regulatory source	Sig req.
DSR Response Pack	Per-request response	DSR Officer	Per request	PDF	36 months	n/a	DPO	Privacy	PDPL Art. 22-26	✓
PIA Report	Privacy impact assessment	DPO	Per high-risk activity	PDF	24 months	Biennial	DPO + CISO	Privacy	PDPL Art. 25	✓ at APPROVED
Personal Data Breach Notification	SDAIA + subject notifications	DPO	Per breach	PDF	60 months	n/a	DPO + CISO	Privacy	PDPL Art. 20 (72h)	✓
Cross-Border Transfer Approval	Per-transfer approval pack	DPO	Per transfer	PDF	Until expiry	Annual	DPO	Privacy	PDPL Art. 29	✓
Consent Record	Captured consent event	System	Per event	JSON, PDF	Per retention	n/a	Auto	Privacy	PDPL Art. 11	—
Disposal Certificate	Verified disposal evidence	Data Owner	Per disposal	PDF	36 months	Per event	DPO	Privacy	PDPL Art. 18	✓ at VERIFY
Processor Due-Diligence Pack	Art. 28 control evidence	DPO	Per processor + annual	PDF, XLSX	12 months	Annual	DPO	Privacy	PDPL Art. 28	✓ at APPROVED
Data Sharing Agreement (Signed)	Per DSA	Legal	Per agreement	PDF	Until expiry	Annual	GC + DPO	Privacy	PDPL Art. 6 + 29	✓ at ACTIVE
Bridge Event Log	Cyber→PDPL automated bridge log	System	Per event	JSON	60 months	n/a	Auto	Privacy	PDPL Art. 20	—
Board Risk Report	Quarterly board pack	Board Secretary	Quarterly	PDF, PPTX	60 months	Quarterly	Board Chair	Reporting	CMA + SAMA	✓
Board Acknowledgement	Board confirmation of receipt	Board Chair	Quarterly	PDF	60 months	n/a	Chair	Reporting	CMA + SAMA	✓
Policy Approval	Signed policy	Policy Owner	Per version	PDF	Until superseded	Annual	Executive	Compliance	ISO 27001 §5	✓
Audit Findings Pack	Internal audit findings	Internal Auditor	Per audit	PDF	60 months	n/a	Audit Committee	Audit	ISO 19011	—

Evidence name	Description	Owner	Frequency	File types	Expiry rule	Review rule	Approval	Module	Regulatory source	Sig req.
Audit Evidence Package	Per-engagement evidence	Internal Auditor	Per engagement	PDF + ZIP	60 months	n/a	Audit Committee	Audit	ISO 19011	—
Regulator Notification Receipt	Filed regulator notice	Regulatory Liaison	Per filing	PDF	60 months	n/a	DPO/CISO	Incident	All regulators	—
Evidence Chain Report	SHA-256 chain verification	System	On-demand + scheduled	JSON, PDF	12 months	Quarterly	Auto	Evidence	ISO 27001 §9	—
Workflow Sign-Off (Digital)	Any digital-signature transaction	Signer	Per transaction	JSON	60 months	n/a	Signer	Signature	—	inherent
Attestation Campaign Response	Per-control attestation cycle	Control Owner	Per cycle	PDF	12 months	Per cycle	Compliance	Compliance	Multi	—
Vendor Cyber Assessment	Cyber-specific TPRM assessment	Vendor Risk Mgr	Annual	PDF	12 months	Annual	CISO	TPRM	NCA + SAMA outsourcing	✓ at APPROVED

File-handling rules

- All evidence is encrypted at rest (SQL Server TDE + per-blob AES-256 envelope).
- Maximum file size: 50 MB per version; chunked upload above 10 MB.
- Allowed types (configurable per tenant): `pdf`, `docx`, `xlsx`, `pptx`, `csv`, `json`, `png`, `jpg`, `zip`.
- SHA-256 of every version is computed on upload and chained against the prior version (`evidence.evidence_versions.chain_hash_sha256`).
- Chain integrity is independently verifiable via the `/api/evidence/chain/{id}/verify` endpoint.